

# Les bases de données avec MySQL(21)

Personnes sur le serveur localhost - phpMyAdmin 2.2.6 - Microsoft Internet Explorer

Fichier Edition Affichage Favoris Outils ?

Précédente Recherche Favoris Média

Adresse <http://127.0.0.1/mysql/index.php> OK Liens >>

**Accueil**

Personnes (1)

**Personnes**

nomprenom

**Base de données Personnes sur le serveur localhost**

| Table                                     | Action                                                                                                                                                 |
|-------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|
| <input type="checkbox"/> <b>nomprenom</b> | <a href="#">Afficher</a> <a href="#">Sélectionner</a> <a href="#">Insérer</a> <a href="#">Propriétés</a> <a href="#">Supprimer</a> <a href="#">Vid</a> |

1 table(s) Somme

Tout cocher / Tout décocher Pour la sélection :

- [Version imprimable](#)
- Exécuter une ou des requêtes sur la base Personnes  
[Documentation](#) :

☒ Réafficher la requête après exécution

Internet

# Les bases de données avec MySQL(22)

Personnes.nomprenom sur le serveur localhost - phpMyAdmin 2.2.6 - Microsoft Internet Explorer

Fichier Edition Affichage Favoris Outils ?

Précédente Recherche Favoris Média

Adresse <http://127.0.0.1/mysql/index.php> OK Liens »

**Accueil**

Personnes (1)

**Personnes**

nomprenom

Base de données *Personnes* - table *nomprenom* sur le serveur *localhost*

[ [Afficher](#) ] [ [Sélectionner](#) ] [ [Insérer](#) ] [ [Vider](#) ] [ [Supprimer](#) ]

|                          | Champ  | Type        | Attributs | Null | Défaut | Extra |                                                                      |
|--------------------------|--------|-------------|-----------|------|--------|-------|----------------------------------------------------------------------|
| <input type="checkbox"/> | nom    | varchar(20) |           | Oui  | NULL   |       | <a href="#">Modifier</a> <a href="#">Supprimer</a> <a href="#">F</a> |
| <input type="checkbox"/> | prenom | varchar(20) |           | Oui  | NULL   |       | <a href="#">Modifier</a> <a href="#">Supprimer</a> <a href="#">F</a> |

↑ Pour la sélection : [Modifier](#) Ou [Supprimer](#)

Index : [\[Documentation\]](#)

Aucune clef n'est définie !

Créer une clef

Espace utilisé :

| Type    | Espace       |
|---------|--------------|
| Données | 136 Octets   |
| Index   | 1 024 Octets |
| Total   | 1 160 Octets |

Statistiques :

| Information     | Valeur     |
|-----------------|------------|
| Format          | dynamique  |
| Enregistrements | 6          |
| Longueur enr. ø | 22         |
| Taille enr. ø   | 193 Octets |

[http://127.0.0.1/mysql/tbl\\_select.php?lang=fr&server=1&db=Personnes&table=nomprenom&goto=tbl\\_properti](http://127.0.0.1/mysql/tbl_select.php?lang=fr&server=1&db=Personnes&table=nomprenom&goto=tbl_properti) Internet

# Les sessions(1)

## ■ Principe

- Est un mécanisme permettant de mettre en relation les différentes requêtes du même client sur une période de temps donnée.
- Les sessions permettent de conserver des informations relatives à un utilisateur lors de son parcours sur un site web
- Des données spécifiques à un visiteur pourront être transmises de page en page afin d'adapter personnellement les réponses d'une application PHP
- Chaque visiteur en se connectant à un site reçoit un numéro d'identification dénommé identifiant de session (SID)
- La fonction `session_start()` se charge de générer automatiquement cet identifiant unique de session et de créer un répertoire. Elle doit être placée au début de chaque page afin de démarrer ou de continuer une session.

```
<?php
    session_start();
    $Session_ID = session_id();
    // $Session_ID = 7edf48ca359ee24dbc5b3f6ed2557e90    ?>
```

# Les sessions(2)

## ■ Principe

- Un répertoire est créé sur le serveur à l'emplacement désigné par le fichier de configuration php.ini, afin de recueillir les données de la nouvelle session.

[Session]

session.save\_path= C:\PHP\sessiondata

; Rép session = \sess\_7edf48ca359ee24dbc5b3f6ed2557e90

- Le fichier php.ini peut également préciser un nom de session par l'option `session.name` ou sa durée de vie par `session.gc_maxlifetime`
- La session en cours peut être détruite par la fonction `session_destroy()`. Cette commande supprime toutes les informations relatives à l'utilisateur.

`session_destroy();`

# Les sessions(3)

## ■ Le traitement des variables de session

- Les variables de session sont chargées dans une session par l'intermédiaire de la fonction `session_register()`

```
<?php
    session_start();
    session_register("nom_variable");
    ...
    session_register("nom_variableN");
?>
```

- Une fois la variable enregistrée, elle est accessible à travers le tableau associatif `$_SESSION["nom_variable"]`

# Les sessions(4)

## ■ Le traitement des variables de session

**Le transport des informations entre les documents est réalisé par l'entremise**

- soit d'un cookie
- soit d'une requête HTTP
  - Cette dernière solution est la plus fiable puisque les cookies peuvent ne pas être acceptés par le client ou celui-ci pourrait les détruire en cours de session.
  - Il suffit de concaténer l'identifiant de session à l'adresse URL de la page cible pour que cette dernière puisse accéder aux informations conservées par la session.

```
echo '<a href=" http://www.site.com/doc.php? '. session_name(). '=' . session_id(). '>
lien</a>'
```

# Les sessions(5)

## ■ Le traitement des variables de session

- Par défaut, PHP tente de passer par les cookies pour sauvegarder l'identifiant de session dans le cas où le client les accepterait. Il est possible d'éviter cela, il suffit de désactiver l'option de configuration `session.use_cookies` dans le fichier `php.ini`.

[Session]

`session.use_cookies 0; // désactive la gestion des sessions par cookie`

# Les sessions(6)

## Exemple

```
<!-- Fichier : formulaire.html -->
<html><body>
  <form method="post" action="traitement.php">
    <table border="0">
      <tr>
        <td><u>Nom :</u></td>
        <td><input type="text" name="Nom" size="20" value="RIVES"></td></tr>
      <tr>
        <td><u>Prénom :</u></td>
        <td><input type="text" name="Prenom" size="20" value="Jean-Pierre"></td></tr>
      <tr>
        <td><u>eMail :</u></td>
        <td><input type="text" name="cEmail" size="20" value="du@du.com"></td></tr>
      <tr><td></td>
      <td><input type="submit" name="soumettre" value="Envoyer"></td></tr></table>
    </form>
  </body>
</html>
```

# Les sessions(7)

```
<?
session_start();
$nom = $_POST["Nom"];
$prenom = $_POST["Prenom"];
$email = $_POST["cEmail"];
session_register("nom");
session_register("prenom");
session_register("email");
$_SESSION["nom"]=$nom;
$_SESSION["prenom"]=$prenom;
$_SESSION["email"]=$email;
header("Location: session.php?" . session_name() . "=" . session_id());
?>
```



# Les sessions(8)

```
<?
    session_start();
?>
<html><body><?
echo("<u>Identifiant de session :</u> <b>"
      . session_id() . "</b><br>");
echo("<u>Nom de la session :</u> <b>"
      . session_name() . "</b><br><br>");
echo("<u>Nom :</u> <b>". $_SESSION["nom"] . "</b><br>");
echo("<u>Prénom :</u> <b>". $_SESSION["prenom"] . "</b><br>");
echo("<u>eMail :</u> <b>". $_SESSION["email"] . "</b><br>");
//session_destroy();
?>
</body>
</html>
```

# Les sessions (9)

## ■ Les fonctions de sessions

**session\_start()** -- Initialise les données de session

**session\_id()** -- Affecte et/ou retourne l'identifiant de session courante

**session\_name()** -- Affecte et/ou retourne le nom de la session courante

**session\_register()** -- Enregistre une variable dans la session courante

**session\_destroy()** -- Détruit toutes les données enregistrées d'une session

**session\_is\_registered()** -- Indique si une variable a été enregistrée dans la session ou pas

**session\_unregister()** -- Supprime une variable dans la session courante

**session\_unset()** -- Détruit toutes les variables de session

**session\_cache\_expire()** -- Retourne la date d'expiration du cache de la session

**session\_save\_path()** -- Affecte et/ou retourne le chemin de sauvegarde de la session courante

**session\_decode()** -- Décode les données de session à partir d'une chaîne

**session\_encode()** -- Encode les données de session dans une chaîne

# Les sessions (10)

## ■ Quelles sont les erreurs possibles ?

### ● *Répertoire de session inaccessible*

*Warning: open(/tmp\sess\_3c80883ca4e755aa72803b05bce40c12, O\_RDWR)  
failed: m (2) in c:\phpdev\www\bp\header.php on line 2*

Le répertoire de sauvegarde est défini dans le **php.ini** : `session.save_path = /tmp`

Il faut donc

Créer un répertoire

Lui donner les droits d'écriture pour tous

En spécifier le chemin dans le **php.ini**

### ● *PHP n'est pas autorisé à utiliser les sessions*

Il faut s'assurer que le PHP est bien autorisé à créer des sessions. C'est juste un paramètre à activer. Faire un **phpinfo()** pour voir ces paramètres. La commande **phpinfo()** se contente d'afficher dans le navigateur le contenu du fichier de configuration **php.ini**.

# Les sessions (11)

## ■ Quelles sont les erreurs possibles ?

### ● Avoir déjà écrit dans la page

*Warning: Cannot send session cookie - headers already sent by (output started at /home/SiteWeb/SiteAnalyse/index.php:3) in /home/SiteWeb/SiteAnalyse/index.php on line 6*

Cette erreur survient lorsqu'on tente d'ouvrir une session après avoir déjà écrit dans le document, ce qui interdit.

Ce qu'il ne faut pas faire :

```
<html>
<body>
<?php session_start();
...
```

ceci non plus :

```
<?php echo "<html>";
...
session_start();
```

# La gestion des connexions aux sites web (1)

## ■ Principe

- Le langage PHP dispose de plusieurs outils permettant de gérer les connexions des utilisateurs sur un site web
  - Il existe trois états possibles en ce qui concerne le statut des connexions.
    1. **NORMAL** : signifie que la connexion est ouverte et le script est en cours d'exécution.
    2. **ABORTED** : signifie que le client a annulé la connexion et le script est arrêté par défaut.
    3. **TIMEOUT** : signifie que le script a provoqué une déconnexion due à la fin de la durée d'exécution convenue.
  - Les deux états **ABORTED** et **TIMEOUT** peuvent survenir en même temps dans le cas où d'une part si PHP est configuré de telle sorte à ignorer les déconnexions et d'autre part lorsque le script arrive à expiration

# La gestion des connexions aux sites web(2)

## ■ Principe

- Le langage PHP dispose de plusieurs outils permettant de gérer les connexions des utilisateurs sur un site web
  - L'état ABORTED en principe interrompt logiquement le script dès que l'utilisateur se déconnecte du site. Toutefois, il est possible de modifier ce comportement en activant l'option de configuration `ignore_user_abort` dans le fichier `php.ini`.
  - Si une fonction de fermeture a été enregistrée avec l'instruction `register_shutdown_function`, le moteur de script se rendra compte après que le client se soit déconnecté puis lors de la prochaine exécution du script que celui ci n'est pas terminé, ce qui provoquera l'appel de la fonction de fermeture mettant fin au script.
  - Lorsque le script se termine normalement, cette fonction sera également appelée.

# La gestion des connexions aux sites web (3)

## ■ Principe

- L'instruction `connection_aborted` permet d'exécuter une fonction spécifique à la déconnexion d'un client. Si la déconnexion est effective, la fonction `connection_aborted` retourne true.
- Un script expire par défaut après une durée de 30 secondes. Néanmoins, ce temps peut être modifié par l'intermédiaire de l'option de configuration `max_execution_time` dans le fichier `php.ini`.
- Une fonction se chargeant de terminer le script sera appelée si le délai arrive à expiration ou si le client se déconnecte.
- Les fonctions `connection_timeout`, `connection_aborted` et `connection_status` permettent respectivement de vérifier si l'état de la connexion est ABORTED, TIMEOUT et les trois états possibles.

# La gestion des connexions aux sites web (4)

## ■ Les fonctions de connexions

**connection\_aborted();**

vérifie si le client a abandonné la connexion.

**connection\_status();**

retourne le statut de la connexion.

**connection\_timeout();**

vérifie l'expiration du script en cours.

**ignore\_user\_abort(paramètre);**

détermine si lors de la déconnexion d'un client, le script doit continuer ou arrêter son exécution.

Le paramètre peut valoir soit '0' pour un comportement normal, '1' pour un abandon et '2' pour une expiration.

# Les en-têtes HTTP (1)

## ■ Principe

- Les entêtes sont des informations envoyées lors de chaque échange par le protocole HTTP entre un navigateur et un serveur
  - Informations sur les données à envoyer dans le cas d'une requête
- Permettent aussi d'effectuer des actions sur le navigateur comme le transfert de cookies ou bien une redirection vers une autre page
  - Ce sont les premières informations envoyées au navigateur (pour une réponse) ou au serveur (dans le cas d'une requête),
    - elles se présentent sous la forme: en-tête: valeur
- la syntaxe doit être rigoureusement respectée
  - aucun espace ne doit figurer entre le nom de l'en-tête et les deux points (:). Un espace doit par contre figurer après celui-ci

# Les en-têtes HTTP (2)

## ■ Principe

- PHP fournit une fonction permettant d'envoyer des en-tête HTTP manuellement du serveur au navigateur
  - **booléen header(chaîne en-tête HTTP)**
- La fonction header() doit être utilisée avant tout envoi de données HTML au navigateur

- Exemples

- Rediriger le navigateur vers une nouvelle page:

```
<?  
header("location: http://www.monsite.fr/"); ?>
```

- Pour envoyer au navigateur une image créé à la volée

```
<?  
header("Content-Type: image/gif");  
imagegif($image); // envoi de l'image au navigateur // code générant l'image  
?>
```

# Les en-têtes HTTP (3)

## ■ Récupérer les en-têtes de la requête

- Alors que la fonction `header()` permet d'envoyer des en-têtes HTTP au navigateur, PHP fournit une seconde fonction permettant de récupérer dans un tableau l'ensemble des en-têtes HTTP envoyées par le navigateur

Tableau `getallheaders()`;

- Le tableau retourné par la fonction contient les en-têtes indexés par leur nom
- Exemple : un script permettant par exemple de récupérer des en-têtes particuliers.

```
<?
$headers = getallheaders();
foreach ($headers as $nom => $contenu) {
    echo "headers[$nom] = $contenu<br />\n";
}
?>
```

# Les en-têtes HTTP (4)

## ■ Les fonctions HTTP

**header(chaine);**

envoie une entête HTTP avant toute commande PHP.

**true | false = headers\_sent();**

vérifie si les entêtes HTTP ont bien été envoyés

**setcookie(nom, valeur [, date\_expiration [, chemin [, domaine [, sécurisation]]]]);**

envoie un cookie.

# *Création d'images à la volée (1)*

- PHP **ne se limite pas** à la génération de pages HTML
- Il peut aussi servir à **créer et manipuler d'autres types de documents**
- Notamment des **images**, au travers dans un grand **choix de formats**, comme GIF , PNG , JPEG , WBMP...
- PHP peut même **générer** directement des images pour le navigateur, avec **la bibliothèque GD** .
- GD et PHP auront aussi **besoin d'autres bibliothèques**, en fonction des formats que vous souhaitez utiliser.
- Vous pouvez utiliser les fonctions PHP pour obtenir les tailles des images aux formats JPEG , GIF , PNG , SWF, TIFF et JPEG2000 .

## *Création d'image à la volée (2)*

- **PHP doit définir, dans l'entete HTTP, le type du document envoyé au navigateur**

fichier rotation\_test.php

```
<?php
```

```
header("Content-type: image/png");
```

```
$im = imagecreatefrompng("test.png");
```

```
$im = imagerotate($im, 90, 0);
```

```
imagepng($im);
```

```
?>
```

fichier test.htm

```
<html><body><img src='rotation_test.php'></body></html>
```

# *Création d'image à la volée (3)*

## ■ **Chargement d'images depuis des fichiers existants**

- `imagecreatefromgif ( string filename )`
- `imagecreatefromjpeg ( string filename )`
- `imagecreatefrompng ( string filename )`
- `imagecreatefromwbmp ( string filename )`
- `imagecreatefromstring ( string filename )`

le type est automatiquement détecté

## ■ **Création d'une image vierge**

- `imagecreate ( int x_size , int y_size )`
- `imagecreatetruecolor ( int x_size , int y_size )`

# *Création d'image à la volée (4)*

## ■ **Redimensionnement**

**int imagecopyresized** ( resource dst\_image , resource src\_image , int dst\_x , int dst\_y , int src\_x , int src\_y , int dst\_w , int dst\_h , int src\_w , int src\_h )

imagecopyresized copie une partie rectangulaire d'une image dans une autre image.

Si les dimensions de la source et de la destination ne sont pas égales, un étirement adéquat est effectué pour faire correspondre

**bool imagecopyresampled** ( resource dst\_image , resource src\_image , int dst\_x , int dst\_y , int src\_x , int src\_y , int dst\_w , int dst\_h , int src\_w , int src\_h )

copie une zone rectangulaire de l'image src\_im vers l'image dst\_im . Durant la copie, la zone est rééchantillonnée de manière à conserver la clarté de l'image . Cette fonction retourne TRUE en cas de succès, FALSE en cas d'échec.

## *Création d'image à la volée (4)*

- *Dessiner sur une image*
- *imagechar ( resource image , int font , int x , int y , string c , int color )*
- *imagestring ( resource image , int font , int x , int y , string c , int color )*
- *imagearc ( resource image , int cx , int cy , int w , int h , int s , int e , int color )*

# Mail (1)

- **La fonction mail envoie un message électronique.**

**Syntaxe :**

`mail($recipient, $subject, $message[, $headers, $params]);`

**Exemple :**

`$message = "Bonjour, ceci est mon message.";`

`$objet = "Bonjour"`

`mail("info@aricia.fr", $objet, $message);`

*Cette fonction ne marche que si un programme de messagerie électronique (appelé « mailer ») est préalablement installé sur le serveur.*

# Mail (2)

## ■ Exemple plus complet :

```
<?php
$recipient = "Tony <tony@tony.com>,";
$recipient .= "Peter <peter@peter.net>";
$subject = "Notre rendez-vous";
$message = "Je vous propose le samedi 15 juin \n";
$message .= "--\r\n";           // Délimiteur de signature
$message .= "Hugo";
$headers = "From: Hugo <hugo@hugo.com>\n";
$headers .= "Content-Type: text/html; charset=iso-8859-1\n";
$headers .= "Cc: bruno@aricia.fr\n";
mail($recipient, $subject, $message, $headers);
?>
```

# Principes de sécurité (1)

- veiller à **limiter** au strict nécessaire **les droits et permissions de l'utilisateur** : il vaut mieux l'entendre se plaindre de son manque de liberté plutôt que de constater les dégâts causés par une trop grande libéralité (principe universel)
- ne **jamais faire confiance aux données transmises** par l'utilisateur (encore moins à l'internaute !)
  - **SQL Injection**
  - **Javascript injection**
- toujours **tester l'existence / la validité d'un fichier / code à inclure** : et s'il n'était pas celui que vous croyiez ?
- Regarder régulièrement les **fichiers journaux (logs)**
- **Mettre des “alarmes”** dans votre code, aux endroits stratégiques (authentification), envoyées par mail ou stockées dans une base de données

# Principes de sécurité (2)

- un **contrôle des données côté client** est bien pratique, mais **illusoire** : quoi de plus simple que de désactiver Javascript ? Seul un **contrôle côté serveur** peut prétendre être **efficace**.
- **préférer**, quand cela est possible, la **méthode POST** à la méthode GET : les variables dans l'url, ça fait mauvais genre
- **ne pas confondre complexité et sécurité** : si votre système de sécurité vous échappe, considérez que vous n'êtes pas en sécurité. De toute façon, **vous n'êtes jamais en sécurité**.
- s'efforcer de **tenir à jour système serveur et interpréteur PHP** avec les dernières versions stables : quand la catastrophe aura eu lieu, ce sera ça de moins à vous reprocher...

# Principes de sécurité (3)

## ■ Masquer PHP

Configurer le serveur web pour qu'il utilise plusieurs extensions de fichiers avec PHP

Vous pouvez utiliser des informations déroutantes comme ceci :

- **Masquer PHP avec un autre langage**

```
# Faire que le code PHP ressemble à un autre langage
AddType application/x-httpd-php .asp .py .pl
```

- **Masquer PHP avec des types inconnus**

```
# Faire que le code PHP ressemble à un autre langage qui n'existe pas
AddType application/x-httpd-php .bop .foo .133t
```

- **cachez-le sous forme de html.**

Cela a un léger impact négatif sur les performances générales, car tous les fichiers HTML seront aussi analysés et traités par le moteur PHP :

Utiliser le type html pour les extensions PHP

```
# Faire que le code PHP ressemble à du html
AddType application/x-httpd-php .htm .html
```